

COMP431 Computer Security

Semester Project Topics (not tentative list, more like a guide if needed)

- Identity-Aware Reverse Proxy (Mini Zero Trust Gateway): Build a gateway that sits in front of 2-3 internal services (real or mock) and enforces user authentication plus authorization (RBAC or ABAC). Include protections such as rate limiting and detailed audit logs. Evaluate by attempting unauthorized access, brute force logins, and token misuse in a local lab.
- Secure Authentication Service (Password Hashing + MFA + Abuse Controls): Implement a small login service that demonstrates secure password storage (Argon2 or bcrypt with salts) and MFA (TOTP), plus defenses like lockout, rate limiting, and secure sessions. Evaluate by running scripted credential stuffing and brute force attempts, then document what gets blocked and what is logged.
- Mini WAF Middleware + Attack Replay Harness (Web Defense Simulation): Create a reverse proxy that detects and blocks common web attack patterns (SQL injection, XSS payloads, path traversal) and logs decisions with reasons. Pair it with a replay harness that runs a repeatable suite of payloads against a deliberately vulnerable local app. Measure block rate, false positives, and latency overhead.
- Ransomware-Resilient Folder (Benign Attack Simulation + Recovery): Build a monitored folder service that detects ransomware-like behavior (mass rename, encrypt, delete) using safe scripts and protects data with versioning and fast restore. Evaluate detection time and recovery completeness on a controlled dataset. Document how design choices reduce damage.
- Secure Microservices Lab with Mutual TLS + Service Authorization): Implement 2-3 microservices that communicate only using mutual TLS, where certificates authenticate services and policy restricts which service can call which endpoint. Evaluate by attempting unauthorized calls from a rogue service container and verifying that traffic is encrypted and access is denied.
- Digital Forensics Case Simulator (Disk Image, Timeline, Evidence): Generate a synthetic incident inside a virtual machine (file staging, suspicious logins, persistence-like artifacts) and then perform forensic analysis to reconstruct a timeline and key actions. The deliverable is a case report with artifact-backed claims, plus a repeatable method to recreate the scenario.
- LLM-assisted Security Audit: Build a local LLM-assisted security auditing tool that runs only on the student's own machine and is used only on code and system configurations they are authorized to analyze. The prototype will combine outputs from free security tools (e.g. Semgrep/Bandit/Trivy) with a locally running LLM that triages findings, explains risk and impact, and produces a prioritized remediation checklist with verification steps. Evaluate effectiveness by running scans before and after applying safe fixes and hardening changes, demonstrating measurable improvement without performing any exploitation or sending sensitive data off-device.

IMPORTANT NOTE: MUST run locally on your own machine!!!